

# Vulnerability Assessment & Penetration Testing First Audit Report of 'SMART Rajasthan Android Application' for Department of Information Technology & Communication (DoIT&C)

|                             |                                                          |
|-----------------------------|----------------------------------------------------------|
| <b>Report Release Date</b>  | 30.06.2026                                               |
| <b>Type of Audit</b>        | Vulnerability Assessment & Penetration Testing           |
| <b>Type of Audit Report</b> | First audit report                                       |
| <b>Period</b>               | 30 <sup>th</sup> June 2026 to 30 <sup>th</sup> June 2026 |

|                                                                                                                                                                                                                                                                                |                                                                                                                                                                                                                                                                                                                                                     |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Audit Conducted By:</b>                                                                                                                                                                                                                                                     | <b>Audit Conducted For:</b>                                                                                                                                                                                                                                                                                                                         |
| <b><u>Company Information:</u></b><br><br>Dreamworks Infotech Private Limited<br>Ranchi, Jharkhand - 834008<br><br><a href="mailto:support@dwinfotech.in">support@dwinfotech.in</a><br><br> | <b><u>Company Information:</u></b><br><br>Department of Information Technology & Communication (DoIT&C)<br><br><b><u>Report Handed Over To:</u></b><br><br>Department of Information Technology & Communication (DoIT&C)<br><br><b>Name:</b> Siddharth Mittal<br><b>Email:</b> <a href="mailto:siddmittal@deloitte.com">siddmittal@deloitte.com</a> |

**Disclaimer:** This document is a confidential document of [SMART Rajasthan Android Application]. No part of this publication may be reproduced, stored in a retrieval system or transmitted in any form or by any means, whether electronic, mechanical, photocopying, recording or otherwise, without the written permission of [Department of Information Technology & Communication (DoIT&C)] This document includes confidential information related to [SMART Rajasthan Android Application] and should not be distributed to any persons other than those mentioned in the distribution list herein.

# Document Control

| Document Preparation    |                                                                                                                                                                              |
|-------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Document Title</b>   | Vulnerability Assessment & Penetration Testing First Audit Report of 'SMART Rajasthan Android Application' for Department of Information Technology & Communication (DoIT&C) |
| <b>Document ID</b>      | DWI/IS/SMD/MOB/26-27/83                                                                                                                                                      |
| <b>Document Version</b> | 1.0                                                                                                                                                                          |
| <b>Prepared by</b>      | Kamal Kishor                                                                                                                                                                 |
| <b>Reviewed by</b>      | Praveen Kr. Kachhap                                                                                                                                                          |
| <b>Approved by</b>      | Anmol Akash Khalkho                                                                                                                                                          |
| <b>Released by</b>      | Kamal Kishor                                                                                                                                                                 |
| <b>Release date</b>     | 30.06.2026                                                                                                                                                                   |

| Document Change History |      |                            |
|-------------------------|------|----------------------------|
| Version                 | Date | Remarks / Reason of change |
| N/A                     | N/A  | N/A                        |

| Document Distribution List |                                                               |                    |                                                                      |
|----------------------------|---------------------------------------------------------------|--------------------|----------------------------------------------------------------------|
| Name                       | Organization                                                  | Designation        | Email Id                                                             |
| Siddharth Mittal           | Department of Information Technology & Communication (DoIT&C) | Associate Director | <a href="mailto:siddmittal@deloitte.com">siddmittal@deloitte.com</a> |

# Contents

|                                                                         |           |
|-------------------------------------------------------------------------|-----------|
| Document Control .....                                                  | 2         |
| Contents .....                                                          | 3         |
| Introduction .....                                                      | 4         |
| Engagement Scope .....                                                  | 5         |
| Details of the Auditing team .....                                      | 6         |
| Audit Activities and Timelines .....                                    | 7         |
| Audit Methodology and Criteria /Standard referred for audit .....       | 8         |
| Tools/ Software used .....                                              | 9         |
| Executive Summary .....                                                 | 10        |
| Detailed Observations .....                                             | 19        |
| <b>Manual Testing Observations .....</b>                                | <b>19</b> |
| 1. Possible Brute Force Attack .....                                    | 19        |
| 2. Root not detected by App .....                                       | 21        |
| 3. App installed and run-on emulator .....                              | 23        |
| 4. Use of Implicit Intent Filter .....                                  | 24        |
| 5. App Link assetlinks.json file not found .....                        | 25        |
| 6. User enumeration .....                                               | 26        |
| 7. Padding Oracle Attacks .....                                         | 28        |
| 8. App can be installed on a vulnerable unpatched Android version ..... | 29        |
| <b>Automated Tool Testing Observations .....</b>                        | <b>30</b> |
| Appendices .....                                                        | 31        |

# Introduction

This document outlines the findings of a Vulnerability Assessment & Penetration Testing (VAPT) conducted by Dreamwork Infotech on the **SMART Rajasthan Android Application**, developed under the **Department of Information Technology & Communication (DoIT&C)**.

The objective of the assessment was to identify vulnerabilities in the mobile application as per the **OWASP Mobile Top 10 Vulnerabilities** and other known vulnerabilities. The assessment was conducted on **test Apk**.

This assessment report illustrates the observations of the audit for the test Apk in scope.

| Sl. No. | In-Scope Item                                            |
|---------|----------------------------------------------------------|
| 1       | SMART Rajasthan Android Application - app-release_3_.apk |

The **SMART Rajasthan Android Application**, developed by the **Department of Information Technology & Communication (DoIT&C)**, is a digital governance platform designed to facilitate secure and efficient delivery of citizen-centric services across Rajasthan. The application enables seamless access to government services, real-time data management, service request processing, and centralized monitoring, helping improve operational efficiency, transparency, accountability, security, and the overall citizen experience within the state's digital governance ecosystem.

The security assessment of the **SMART Rajasthan Android Application**, developed under the **Department of Information Technology & Communication (DoIT&C)**, was conducted from **30<sup>th</sup> June 2026** to **30<sup>th</sup> June 2026**. A total of **Eight** vulnerabilities were identified, including **Two high**, and **four medium** severity issues. While no critical vulnerabilities were detected, several areas require remediation to strengthen the application's overall security posture.

The following describes the out-of-scope items for assessment.

| Sl. No. | Out-of-Scope Item |
|---------|-------------------|
| 1.      | After Logged-In   |

## Engagement Scope

| S. No | Asset Description                                        | Criticality of Asset | Internal IP Address | URL | Public IP Address | Location | Hash Value(in case of applications)                                             | Version (in case of applications) | Other details such as make and model in case of network devices or security devices. |
|-------|----------------------------------------------------------|----------------------|---------------------|-----|-------------------|----------|---------------------------------------------------------------------------------|-----------------------------------|--------------------------------------------------------------------------------------|
| 1     | SMART Rajasthan Android Application - app-release_3_.apk | High                 | N/A                 | N/A | N/A               | N/A      | SHA256 -<br>0864f4bf83af4c3e1fc668483e849d62d0b41baebf9cad3a2e366cb<br>c0d5e7e7 | 1.1.11                            | N/A                                                                                  |

Date up to which the list has been updated: 30.06.2026 *(to be shared by Auditee organization with the Auditing organization before commencing the audit assignment)*

## Details of the Auditing team

| S. No | Name                | Designation                         | Email Id                                                         | Professional Qualifications/ Certifications                      | Whether the resource has been listed in the Snapshot information published on CERT-In's website (Yes/No) |
|-------|---------------------|-------------------------------------|------------------------------------------------------------------|------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------|
| 1     | Praveen Kr. Kachhap | Sr. Information Security Consultant | <a href="mailto:praveen@dwinfotech.in">praveen@dwinfotech.in</a> | a. Certified Ethical Hacker (CEH)<br>b. ISO 27001 Associate      | Yes                                                                                                      |
| 2     | Kamal Kishor        | Information Security Consultant     | <a href="mailto:kamal@dwinfotech.in">kamal@dwinfotech.in</a>     | a. Certified AppSec Practitioner (CAP)<br>b. ISO 27001 Associate | Yes                                                                                                      |

## Audit Activities and Timelines

| Sl. No. | Audit Phase | Initiation Date            | Completion Date            |
|---------|-------------|----------------------------|----------------------------|
| 01      | First Audit | 30 <sup>th</sup> June 2026 | 30 <sup>th</sup> June 2026 |

# Audit Methodology and Criteria /Standard referred for audit

## **Vulnerability Assessment-:**

Systematic examination of an information system or product to determine the adequacy of security measures, identify security deficiencies, provide data from which to predict the effectiveness of proposed security measures, and confirm the adequacy of such measures after implementation.

(SOURCE: SP 800-53A; CNSSI-4009)

## **Penetration Testing -:**

Security testing in which evaluators mimic real-world attacks in an attempt to identify ways to circumvent the security features of an application, system, or network. Penetration testing often involves issuing real attacks on real systems and data, using the same tools and techniques used by actual attackers. Most penetration tests involve looking for combinations of vulnerabilities on a single system or multiple systems that can be used to gain more access than could be achieved through a single vulnerability.

(SOURCE: SP 800-115)

## **Black Box Testing-:**

A test methodology that assumes no knowledge of the internal structure and implementation detail of the assessment object. Also known as black box testing.

(SOURCE: SP 800-53A)

Our testing methodology is aligned with the following security frameworks, industry standards and guidelines:

| Sl. No. | Frameworks, Standards, Guidelines and Vulnerability Categories   |
|---------|------------------------------------------------------------------|
| 1       | OWASP Mobile Top 10                                              |
| 2       | CERT-In Guidelines                                               |
| 3       | MASVS v2.0.0 (Mobile Application Security Verification Standard) |
| 4       | MASTG v1.7.0 (Mobile Application Security Testing Guide)         |
| 5       | PTES (Penetration Testing Execution Standard)                    |



## Tools/ Software used

| S. No | Name of Tool/Software used | Version of the tool /Software used | Open Source/Licensed |
|-------|----------------------------|------------------------------------|----------------------|
| 1     | Kali Linux                 | 2024.1                             | Open Source          |
| 2     | Dex2jar                    | 2.0                                | Open Source          |
| 3     | jd-gui windows             | 1.6.6                              | Open Source          |
| 4     | MobSF                      | 4.2.9                              | Open Source          |
| 5     | apktool                    | 2.10.0                             | Open Source          |
| 6     | Platform Tool              | N/A                                | Open Source          |
| 7     | GennyMotion                | 3.9.0                              | Open Source          |
| 8     | Apkid                      | 2.1.5                              | Open Source          |
| 9     | Burp Suite                 | 2024.9.4                           | Licensed             |

# Executive Summary

## A. Purpose of the assessment:

The purpose of this assessment is to identify security weaknesses, misconfigurations, and exploitable vulnerabilities within the mobile application that could compromise data confidentiality, integrity, or availability. The assessment aims to enhance the application's security posture by providing actionable recommendations aligned with industry best practices and compliance requirements. This assessment is intent to perform a comprehensive and risk-based evaluation that identifies real-world threats and practical mitigation strategies to ensure meaningful security improvements, foster compliance readiness, and safeguard the application against evolving cyber risks.

## B. Stakeholders involved (Client, Auditor/Auditing Agency):

| Auditee/Client:                                                                                           | Auditor/Auditing Agency:                                                                                                                                                             |
|-----------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| SMART Rajasthan Android Application -<br>Department of Information Technology &<br>Communication (DoIT&C) | Dreamworks Infotech Private Limited<br>Ranchi, Jharkhand - 834008<br><br><i>"This Organization is empanelled by CERT-In for<br/>providing information Security Auditing Service"</i> |

## C. Audit Timeline:

| Sl. No. | Audit Phase | Initiation Date            | Completion Date            |
|---------|-------------|----------------------------|----------------------------|
| 01      | First Audit | 30 <sup>th</sup> June 2026 | 30 <sup>th</sup> June 2026 |

## D. Overview of the Target application:

It was observed that the **SMART Rajasthan Android Application**, developed by the **Department of Information Technology & Communication (DoIT&C)**, is intended to facilitate secure and efficient access to citizen-centric government services, digital service delivery, and real-time management of service-related information. The scope of the security audit included User Acceptance Testing (UAT), module accessibility, input validation, session management, and the security assessment of third-party libraries. However, the audit excluded backend infrastructure, server-side logic, and performance testing from its scope.

**E. Assessment Scope:**

The scope of this Assessment was defined in consultation with the client and included the following components:

| Sl. No. | Assessment Scope                 |                                                                                                                                                                                                                                                                                                       |
|---------|----------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1.      | Application Name                 | SMART Rajasthan Android Application - app-release_3_.apk                                                                                                                                                                                                                                              |
| 2.      | Version (If Applicable)          | 1.0.0                                                                                                                                                                                                                                                                                                 |
| 3.      | Hash Value                       | SHA256 -<br>0864f4bf83af4c3e1fc668483e849d62d0b41baebf9cad3a2e366cbc0d5e7e7                                                                                                                                                                                                                           |
| 4.      | Primary UAT URL                  | SMART Rajasthan Android Application - app-release_3_.apk                                                                                                                                                                                                                                              |
| 5.      | Modules Covered (If Applicable): | N/A                                                                                                                                                                                                                                                                                                   |
| 6.      | Authentication Mechanism         | <ul style="list-style-type: none"> <li>• <b>Credentialed access</b> was provided for authenticated user testing, enabling evaluation of role-based functionalities and authorization controls.</li> </ul>                                                                                             |
| 7.      | In-Scope Functionalities         | <ul style="list-style-type: none"> <li>• Input handling and parameter validation</li> <li>• Session management and cookies</li> <li>• Client-side and server-side error handling mechanisms</li> </ul>                                                                                                |
| 8.      | Out-of-Scope Functionalities     | <ul style="list-style-type: none"> <li>• Backend infrastructure (e.g., database servers, internal APIs not exposed via frontend)</li> <li>• Third-party systems or integrations not hosted under the tested domain</li> <li>• Web application (if any)</li> <li>• Load/performance testing</li> </ul> |
| 9.      | Third-Party Services or Modules  | N/A                                                                                                                                                                                                                                                                                                   |
| 10.     | Non-Active URLs (If Applicable): | N/A                                                                                                                                                                                                                                                                                                   |

## F. Methodology

The assessment was conducted using a structured and standards-based approach to identify potential security weaknesses in the Mobile application. The testing included both **automated scanning** and **manual verification** to ensure comprehensive coverage of vulnerabilities.

**The following practices and tools were employed:**

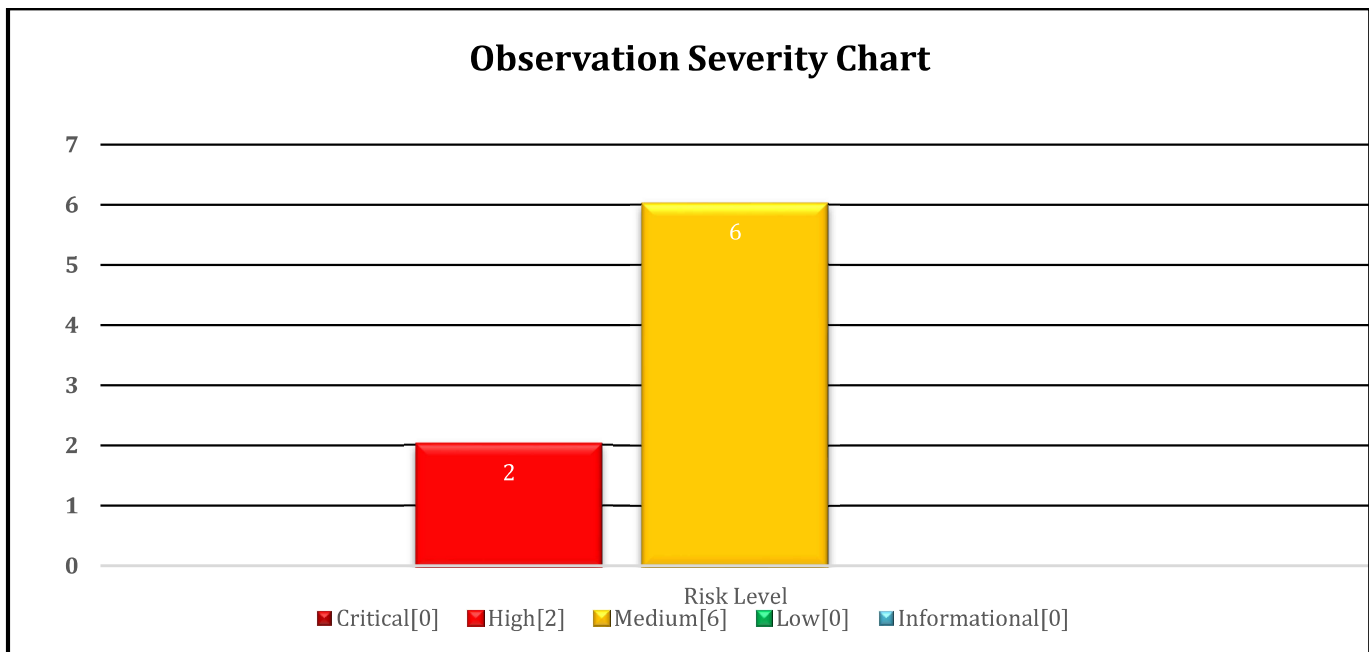
| Testing Approach/Methodology                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   | Tools Used                                                                                                                                                                                                                        | Manual Testing Techniques                                                                                                                                                                                                                                                                                                                                                       |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p>The assessment was conducted to identify all known vulnerabilities based on the comprehensive standards/frameworks like:</p> <ul style="list-style-type: none"> <li>OWASP Mobile Top 10</li> <li>MASVS v2.0.0 (Mobile Application Security Verification Standard)</li> <li>MASTG v1.7.0 (Mobile Application Security Testing Guide)</li> <li>PTES (Penetration Testing Execution Standard)</li> </ul> <p>Along with applicable regulatory framework and directions &amp; guidelines issued by agencies such as CERT-In.</p> | <ul style="list-style-type: none"> <li>Burp Suite Professional</li> <li>Kali Linux</li> <li>Dex2jar</li> <li>jd-gui windows</li> <li>MobSF</li> <li>Apktool</li> <li>Platform Tool</li> <li>GennyMotion</li> <li>Apkid</li> </ul> | <p>Manual testing was performed to validate findings from automated tools and to identify business logic vulnerabilities, including:</p> <ul style="list-style-type: none"> <li>Input validation and injection flaws</li> <li>Broken access control and authentication bypass</li> <li>Session management issues</li> <li>Misconfigured security headers and cookies</li> </ul> |

## G. Summary of Vulnerability Findings:

The assessment revealed multiple security risks, including “**Possible Brute Force Attack**”, “**Root not detected by App**”, “**App installed and run-on emulator**”, etc. and the details of the vulnerability in (*Detailed Observations*) section of this report.

During the assessment, a total of **Eight (08)** vulnerabilities were identified. These include (00) **Critical** (02) **High**, (06) **Medium**, (00) **Low**, and (00) as **Informational** severity issues. The summary list of the vulnerability in (*List of Vulnerabilities*) section of this report.

The bar chart below illustrates the distribution of these vulnerabilities by severity level.



**Remediation:** Based on the vulnerabilities identified during the security assessment, the Remediation section outlines measures to fix, mitigate, or eliminate security weaknesses in the application that could be exploited by threat actors.

#### Conclusion:

- **Overall Security Posture:** It can be observed that the **SMART Rajasthan Android Application**, developed under the **Department of Information Technology & Communication (DoIT&C)** demonstrates a weak security posture, as a total of 06 vulnerabilities were identified during the assessment. These include 02 high-risk, 06 medium-risk, and 00 low-risk findings. While no critical vulnerabilities were detected, the presence of multiple high and medium-risk issues highlights significant gaps in security controls which, if not addressed, could potentially be exploited by malicious actors to compromise the confidentiality, integrity, and availability of the application over time.
- **Retesting follow-up audit:** It is recommended that the identified issues be addressed **without delay**, followed by a re-testing exercise to validate the effectiveness of the remediation measures and confirm that all vulnerabilities have been patched or mitigated.

#### H. Remarks:

| S.L No | Particulars                   | Auditor Comments |
|--------|-------------------------------|------------------|
| 01     | Timely Vulnerability Patching | N/A              |
| 02     | Zero-Day Vulnerabilities      | N/A              |

**I. Annexures (If Applicable)**

| S.L No. | Particulars                | Annexure-Ref-No. |
|---------|----------------------------|------------------|
| 01      | Annexures A – Mobsf Report | N/A              |

| S. No | Affected Asset i.e.<br>IP/URL/Application etc.                 | Observation/ Vulnerability title        | CVE/CWE                                           | Control Objective # | Control Name # | Audit Requirement # | Severity | Recommendation                                                                                                                                                                                                                                                                                                           | Reference | New or<br>Repeat observation |
|-------|----------------------------------------------------------------|-----------------------------------------|---------------------------------------------------|---------------------|----------------|---------------------|----------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|------------------------------|
| 1     | SMART Rajasthan<br>Android Application -<br>app-release_3_.apk | Possible Brute<br>Force Attack          | <a href="#">CWE-307</a> & <a href="#">CWE-778</a> | N/A                 | N/A            | N/A                 | HIGH     | <ul style="list-style-type: none"> <li>➤ Rate Limiting / Throttling: Limit the number of login attempts per IP, username, or session.</li> <li>➤ Add CAPTCHA, following the latest security guidelines, ensuring at least 6 characters with an alphanumeric challenge to mitigate automated attacks.</li> </ul>          | N/A       | New                          |
| 2     | SMART Rajasthan<br>Android Application -<br>app-release_3_.apk | Root not<br>detected by<br>App          | <a href="#">CWE-1326</a>                          | N/A                 | N/A            | N/A                 | HIGH     | <ul style="list-style-type: none"> <li>➤ The device/emulator is running as root (whoami returns root).</li> <li>➤ Despite root access, the app does not detect or prevent execution on a rooted device.</li> <li>➤ This means the app lacks root detection or tamper protection mechanisms. should be checked</li> </ul> | N/A       | New                          |
| 3     | SMART Rajasthan<br>Android Application -<br>app-release_3_.apk | App installed<br>and run-on<br>emulator | <a href="#">CWE-926</a>                           | N/A                 | N/A            | N/A                 | Medium   | <p>To mitigate the risk of unauthorized access and ensure compliance with Aadhaar security guidelines:</p> <p>Implement Emulator Detection: -</p> <ul style="list-style-type: none"> <li>➤ Use Android APIs and system checks to detect</li> </ul>                                                                       | N/A       | New                          |

|   |                                                          |                                         |                         |     |     |     |        |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |     |     |
|---|----------------------------------------------------------|-----------------------------------------|-------------------------|-----|-----|-----|--------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----|-----|
|   |                                                          |                                         |                         |     |     |     |        | emulator environments.<br>➤ Abort execution or restrict functionality if an emulator is detected.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |     |     |
| 4 | SMART Rajasthan Android Application - app-release_3_.apk | Use of Implicit Intent Filter           | <a href="#">CWE-927</a> | N/A | N/A | N/A | Medium | <p>➤ App Developers should only export components that need to be exposed to other applications. This will limit what Activities are exposed in the AndroidManifest.xml.</p> <p>➤ They should also stringently validate all data received in Intents.</p> <p>➤ App Developers should only export components that need to be exposed to other applications. This will limit what Activities are exposed in the AndroidManifest.xml. They should also stringently validate all data received in Intents. Where the application expects data to be passed from other applications, consider applying permissions to restrict which applications are allowed to do so. Developers can disable external exposure of any components by specifying android:exported="false" in the application manifest.</p> | N/A | New |
| 5 | SMART Rajasthan Android Application - app-release_3_.apk | App Link assetlinks.json file not found | <a href="#">CWE-939</a> | N/A | N/A | N/A | Medium | <p>➤ App Link asset verification URL (https://smart.rajasthan.gov.in/.well-known/assetlinks.json) not found or configured incorrectly. (Status</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    | N/A | New |



|   |                                                          |                           |                                                       |     |     |     |        |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |     |     |
|---|----------------------------------------------------------|---------------------------|-------------------------------------------------------|-----|-----|-----|--------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----|-----|
|   |                                                          |                           |                                                       |     |     |     |        | Code: None). App Links allow users to redirect from a web URL/email to the mobile app. If this file is missing or incorrectly configured for the App Link host/domain, a malicious app can hijack such URLs. This may lead to phishing attacks, leak sensitive data in the URI, such as PII, OAuth tokens, magic link/password reset tokens and more. You must verify the App Link domain by hosting the assetlinks.json file and enabling verification via [android:autoVerify="true"] in the Activity intent-filter |     |     |
| 6 | SMART Rajasthan Android Application - app-release_3_.apk | User enumeration          | <a href="#">CWE-204</a>                               | N/A | N/A | N/A | Medium | ➤ To implement generic and uniform error messages during login and password reset processes (e.g., “Invalid credentials” or “Invalid details provided”) instead of revealing whether the Attendance ID or Mobile Number is correct.                                                                                                                                                                                                                                                                                   | N/A | New |
| 7 | SMART Rajasthan Android Application - app-release_3_.apk | Padding Oracle Attacks    | <a href="#">CAPE C-463</a><br><a href="#">CWE-649</a> | N/A | N/A | N/A | Medium | Replace the use of AES/CBC/PKCS5Padding and AES/CBC/PKCS7Padding with an authenticated encryption mode such as AES/GCM/NoPadding and ensure cryptographic errors are handled uniformly to prevent Padding Oracle attacks.                                                                                                                                                                                                                                                                                             | N/A | New |
| 8 | SMART Rajasthan Android Application - app-release_3_.apk | App can be installed on a | <a href="#">CWE-1104</a>                              | N/A | N/A | N/A | Medium | ➤ This application can be installed on an older                                                                                                                                                                                                                                                                                                                                                                                                                                                                       | N/A | New |

|  |  |                                               |  |  |  |  |  |                                                                                                                                                                                                                                                                                                              |  |  |
|--|--|-----------------------------------------------|--|--|--|--|--|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--|--|
|  |  | vulnerable<br>unpatched<br>Android<br>version |  |  |  |  |  | version of android that<br>has multiple unfixed<br>vulnerabilities. These<br>devices won't receive<br>reasonable security<br>updates from Google.<br>Support an Android<br>version => 10, API 29 to<br>receive reasonable<br>security updates.<br>➤ Update the app's<br>minSdkVersion to latest<br>version . |  |  |
|--|--|-----------------------------------------------|--|--|--|--|--|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--|--|

# Detailed Observations

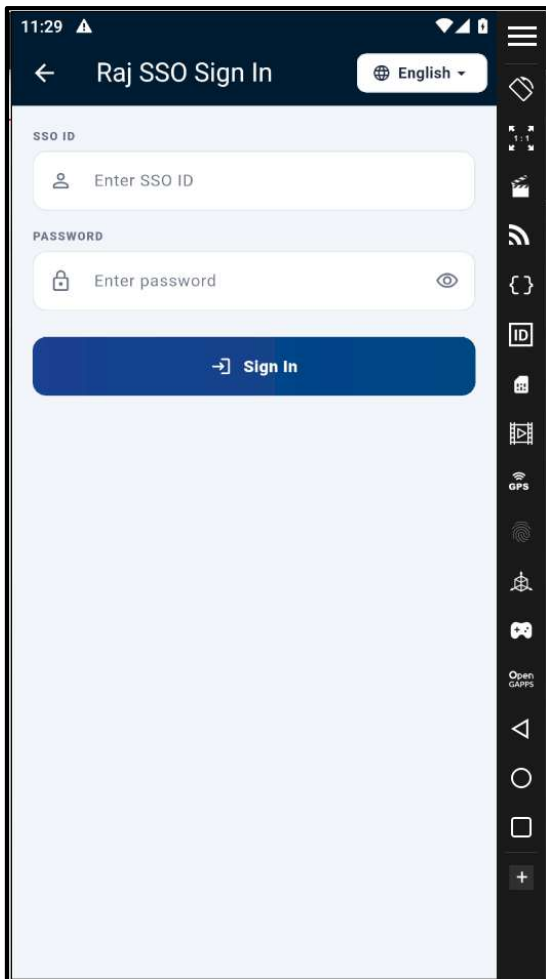
## Manual Testing Observations

### 1. Possible Brute Force Attack

|       |                                                 |                                                                                                                                                                                                                                                                                                                 |
|-------|-------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| i.    | Affected Asset i.e. IP / URL / Application etc. | SMART Rajasthan Android Application - app-release_3_.apk                                                                                                                                                                                                                                                        |
| ii.   | Observation / Vulnerability title:              | Possible Brute Force Attack                                                                                                                                                                                                                                                                                     |
| iii.  | Detailed Observation / Vulnerable point:        | It is recommended to implement a CAPTCHA mechanism.                                                                                                                                                                                                                                                             |
| iv.   | CVE/CWE                                         | <a href="#">CWE-307</a> & <a href="#">CWE-778</a>                                                                                                                                                                                                                                                               |
| v.    | Control Objective:                              | N/A                                                                                                                                                                                                                                                                                                             |
| vi.   | Control Name:                                   | N/A                                                                                                                                                                                                                                                                                                             |
| vii.  | Audit Requirement:                              | N/A                                                                                                                                                                                                                                                                                                             |
| viii. | Severity:                                       | High                                                                                                                                                                                                                                                                                                            |
| ix.   | Recommendation:                                 | <ul style="list-style-type: none"> <li>➤ Rate Limiting / Throttling: Limit the number of login attempts per IP, username, or session.</li> <li>➤ Add CAPTCHA, following the latest security guidelines, ensuring at least 6 characters with an alphanumeric challenge to mitigate automated attacks.</li> </ul> |
| x.    | Reference:                                      | N/A                                                                                                                                                                                                                                                                                                             |
| xi.   | New or Repeat observation:                      | New                                                                                                                                                                                                                                                                                                             |

xii. References to evidences / Proof of Concept:

PoC 1:

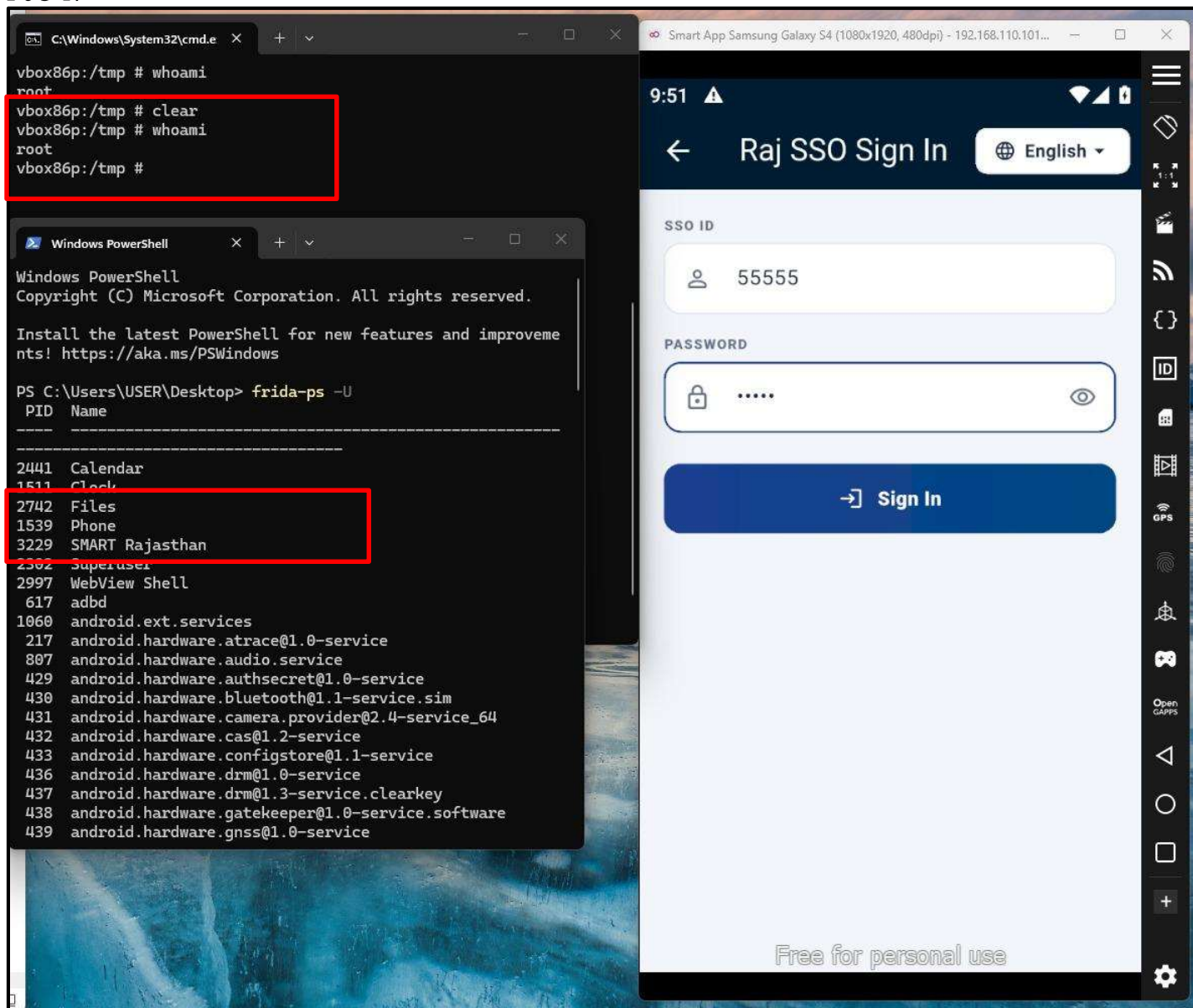


## 2. Root not detected by App

|      |                                             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
|------|---------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| i    | Affected Asset i.e. IP/URL/Application etc. | SMART Rajasthan Android Application - app-release_3_.apk                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| ii   | Observation/Vulnerability title             | Root not detected by App                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| iii  | Detailed observation / Vulnerable point     | <ul style="list-style-type: none"> <li>➤ The device/emulator is running as root (whoami returns root).</li> <li>➤ Despite root access, the app does not detect or prevent execution on a rooted <b>device</b>.</li> <li>➤ This means the app lacks root detection or tamper protection mechanisms.</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| iv   | CVE/CWE                                     | <a href="#">CWE-1326</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| v    | Control Objective                           | N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| vi   | Control Name                                | N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| vii  | Audit Requirement                           | N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| viii | Severity                                    | High                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| ix   | Recommendation                              | <ul style="list-style-type: none"> <li>➤ <b>Implement Comprehensive Root Detection:</b> - Incorporate multiple root detection techniques such as checking for <b>su</b> binaries, root management apps, and unusual system file permissions.</li> <li>➤ <b>Use Device Integrity APIs:</b> - Integrate Android SafetyNet or Play Integrity API to reliably detect rooted or compromised devices.</li> <li>➤ <b>Enforce Security Controls on Rooted Devices:</b> - Restrict app functionality or block usage entirely on devices identified as rooted to protect sensitive data.</li> <li>➤ <b>Add Runtime Integrity Checks:</b> - Detect debugging, tampering, or hooking attempts to prevent manipulation of the app at runtime.</li> <li>➤ <b>Regularly Update Detection Methods:</b> - Continuously update root detection techniques to keep pace with evolving rooting methods.</li> </ul> |
| x    | Reference                                   | N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| xi   | New or Repeat observation                   | New                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |

## xii. References to evidences / Proof of Concept

## PoC 1:

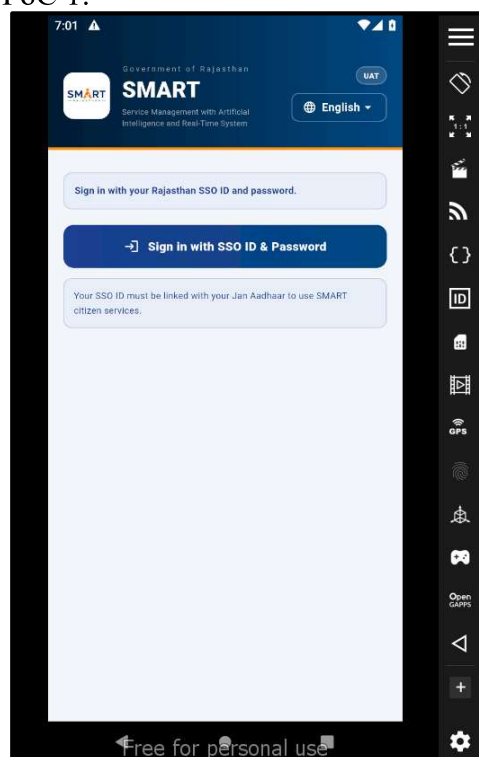


### 3. App installed and run-on emulator

|      |                                             |                                                                                                                                                                                                                                                                                                                                                            |
|------|---------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| i    | Affected Asset i.e. IP/URL/Application etc. | SMART Rajasthan Android Application - app-release_3_.apk                                                                                                                                                                                                                                                                                                   |
| ii   | Observation/Vulnerability title             | App installed and run-on emulator                                                                                                                                                                                                                                                                                                                          |
| iii  | Detailed observation / Vulnerable point     | The Android application is successfully installed and launched on an Android emulator.                                                                                                                                                                                                                                                                     |
| iv   | CVE/CWE                                     | <a href="#">CWE-926</a>                                                                                                                                                                                                                                                                                                                                    |
| v    | Control Objective                           | N/A                                                                                                                                                                                                                                                                                                                                                        |
| vi   | Control Name                                | N/A                                                                                                                                                                                                                                                                                                                                                        |
| vii  | Audit Requirement                           | N/A                                                                                                                                                                                                                                                                                                                                                        |
| viii | Severity                                    | Medium                                                                                                                                                                                                                                                                                                                                                     |
| ix   | Recommendation                              | <p>To mitigate the risk of unauthorized access and ensure compliance with Aadhaar security guidelines:</p> <p>Implement Emulator Detection: -</p> <ul style="list-style-type: none"> <li>➤ Use Android APIs and system checks to detect emulator environments.</li> <li>➤ Abort execution or restrict functionality if an emulator is detected.</li> </ul> |
| x    | Reference                                   | N/A                                                                                                                                                                                                                                                                                                                                                        |
| xi   | New or Repeat observation                   | New                                                                                                                                                                                                                                                                                                                                                        |

#### xii. References to evidences / Proof of Concept

##### PoC 1:



## 4. Use of Implicit Intent Filter

|      |                                             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
|------|---------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| i    | Affected Asset i.e. IP/URL/Application etc. | SMART Rajasthan Android Application - app-release_3_.apk                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| ii   | Observation/Vulnerability title             | Use of Implicit Intent Filter                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| iii  | Detailed observation / Vulnerable point     | ➤ The Android application uses an implicit intent for transmitting sensitive data to other applications. Other applications, possibly untrusted, can read the data that is offered through the Intent                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| iv   | CVE/CWE                                     | <a href="#">CWE-927</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| v    | Control Objective                           | N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| vi   | Control Name                                | N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| vii  | Audit Requirement                           | N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| viii | Severity                                    | Medium                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| ix   | Recommendation                              | <ul style="list-style-type: none"> <li>➤ App Developers should only export components that need to be exposed to other applications. This will limit what Activities are exposed in the AndroidManifest.xml.</li> <li>➤ They should also stringently validate all data received in Intents.</li> <li>➤ App Developers should only export components that need to be exposed to other applications. This will limit what Activities are exposed in the AndroidManifest.xml. They should also stringently validate all data received in Intents. Where the application expects data to be passed from other applications, consider applying permissions to restrict which applications are allowed to do so. Developers can disable external exposure of any components by specifying android:exported="false" in the application manifest.</li> </ul> |
| x    | Reference                                   | N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| xi   | New or Repeat observation                   | New                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |

### xii. References to evidences / Proof of Concept

PoC1:

```
<receiver android:directBootAware="false" android:enabled="true" android:exported="true" android:name="androidx.profileinstaller.ProfileInstallReceiver"
  <intent-filter>
    <action android:name="androidx.profileinstaller.action.INSTALL_PROFILE"/>
  </intent-filter>
</receiver>
```



## 5. App Link assetlinks.json file not found

|      |                                             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
|------|---------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| i    | Affected Asset i.e. IP/URL/Application etc. | SMART Rajasthan Android Application - app-release_3_apk                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| ii   | Observation/Vulnerability title             | App Link assetlinks.json file not found                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| iii  | Detailed observation / Vulnerable point     | The Android App Link verification is not properly configured because the required assetlinks.json file is missing or inaccessible at <a href="https://smart.rajasthan.gov.in/.well-known/assetlinks.json">https://smart.rajasthan.gov.in/.well-known/assetlinks.json</a> , preventing verification of the application's association with the domain.                                                                                                                                                                                                                                                                                                                                                                                       |
| iv   | CVE/CWE                                     | <a href="#">CWE-939</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| v    | Control Objective                           | N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| vi   | Control Name                                | N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| vii  | Audit Requirement                           | N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| viii | Severity                                    | Medium                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| ix   | Recommendation                              | App Link asset verification URL ( <a href="https://smart.rajasthan.gov.in/.well-known/assetlinks.json">https://smart.rajasthan.gov.in/.well-known/assetlinks.json</a> ) not found or configured incorrectly. (Status Code: None). App Links allow users to redirect from a web URL/email to the mobile app. If this file is missing or incorrectly configured for the App Link host/domain, a malicious app can hijack such URLs. This may lead to phishing attacks, leak sensitive data in the URI, such as PII, OAuth tokens, magic link/password reset tokens and more. You must verify the App Link domain by hosting the assetlinks.json file and enabling verification via [android:autoVerify="true"] in the Activity intent-filter |
| x    | Reference                                   | N/A                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| xi   | New or Repeat observation                   | New                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |

### xii. References to evidences / Proof of Concept

#### PoC1:

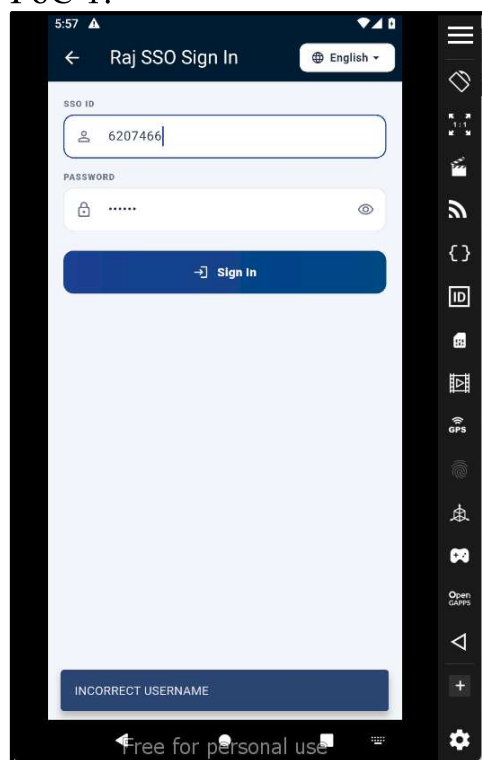
|                                                                                                                                             |      |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
|---------------------------------------------------------------------------------------------------------------------------------------------|------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| App Link assetlinks.json file not found<br>[android:name=gov.rajasthan.smart.MainActivity]<br>[android:host=https://smart.rajasthan.gov.in] | high | App Link asset verification URL ( <a href="https://smart.rajasthan.gov.in/.well-known/assetlinks.json">https://smart.rajasthan.gov.in/.well-known/assetlinks.json</a> ) not found or configured incorrectly. (Status Code: None). App Links allow users to redirect from a web URL/email to the mobile app. If this file is missing or incorrectly configured for the App Link host/domain, a malicious app can hijack such URLs. This may lead to phishing attacks, leak sensitive data in the URI, such as PII, OAuth tokens, magic link/password reset tokens and more. You must verify the App Link domain by hosting the assetlinks.json file and enabling verification via [android:autoVerify="true"] in the Activity intent-filter. |
|---------------------------------------------------------------------------------------------------------------------------------------------|------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

## 6. User enumeration

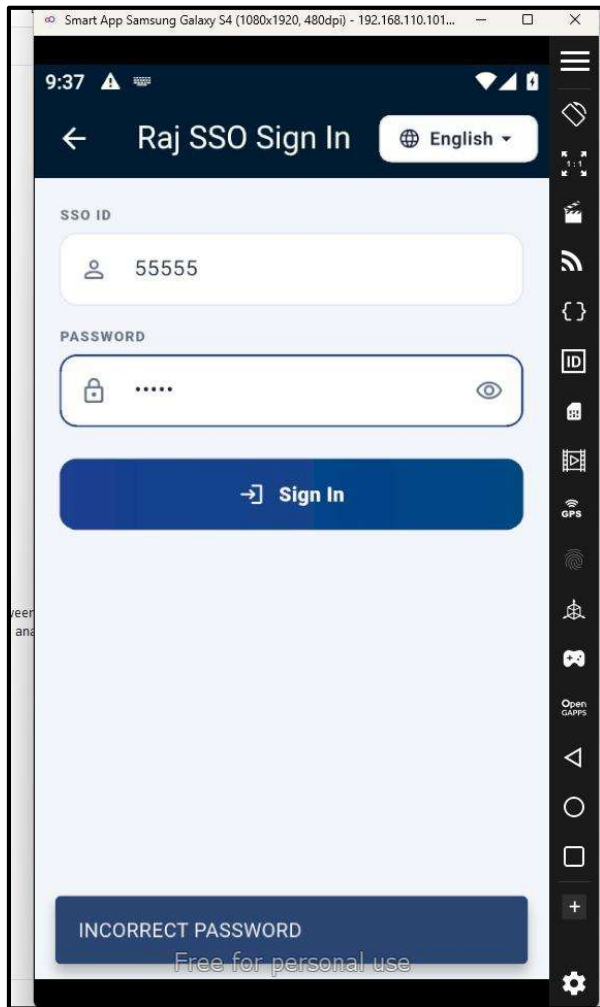
|       |                                                 |                                                                                                                                                                                                                                   |
|-------|-------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| i.    | Affected Asset i.e. IP / URL / Application etc. | SMART Rajasthan Android Application - app-release_3_.apk                                                                                                                                                                          |
| ii.   | Observation / Vulnerability title:              | User enumeration                                                                                                                                                                                                                  |
| iii.  | Detailed Observation / Vulnerable point:        | User enumeration occurs when an application reveals whether a username or email exists, allowing attackers to gather valid user accounts.                                                                                         |
| iv.   | CVE/CWE                                         | <a href="#">CWE-204</a>                                                                                                                                                                                                           |
| v.    | Control Objective:                              | N/A                                                                                                                                                                                                                               |
| vi.   | Control Name:                                   | N/A                                                                                                                                                                                                                               |
| vii.  | Audit Requirement:                              | N/A                                                                                                                                                                                                                               |
| viii. | Severity:                                       | Medium                                                                                                                                                                                                                            |
| ix.   | Recommendation:                                 | To implement generic and uniform error messages during login and password reset processes (e.g., “Invalid credentials” or “Invalid details provided”) instead of revealing whether the Attendance ID or Mobile Number is correct. |
| x.    | Reference:                                      | N/A                                                                                                                                                                                                                               |
| xi.   | New or Repeat observation:                      | New                                                                                                                                                                                                                               |

xii. References to evidences / Proof of Concept:

PoC 1:



PoC 2:



## 7. Padding Oracle Attacks

|      |                                             |                                                                                                                                                                                                                             |
|------|---------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| i    | Affected Asset i.e. IP/URL/Application etc. | SMART Rajasthan Android Application - app-release_3_.apk                                                                                                                                                                    |
| ii   | Observation/Vulnerability title             | Padding Oracle Attacks                                                                                                                                                                                                      |
| iii  | Detailed observation / Vulnerable point     | The application uses the cryptographic transformation AES/CBC/PKCS5Padding in multiple locations within the codebase.<br>1. f/h0.java                                                                                       |
| iv   | CVE/CWE                                     | <a href="#">CAPEC-463</a>   <a href="#">CWE-649</a>                                                                                                                                                                         |
| v    | Control Objective                           | N/A                                                                                                                                                                                                                         |
| vi   | Control Name                                | N/A                                                                                                                                                                                                                         |
| vii  | Audit Requirement                           | N/A                                                                                                                                                                                                                         |
| viii | Severity                                    | Medium                                                                                                                                                                                                                      |
| ix   | Recommendation                              | ➤ Replace the use of AES/CBC/PKCS5Padding and AES/CBC/PKCS7Padding with an authenticated encryption mode such as AES/GCM/NoPadding and ensure cryptographic errors are handled uniformly to prevent Padding Oracle attacks. |
| x    | Reference                                   | N/A                                                                                                                                                                                                                         |
| xi   | New or Repeat observation                   | New                                                                                                                                                                                                                         |

### xii. References to evidences / Proof of Concept

#### PoC1:

```

231.
232.
233.     public Cipher F() {
234.         return Cipher.getInstance("AES/CBC/PKCS7Padding");
235.     }
236.
237.     public Drawable G(int i4) {
238.         int resourceId;
239.         TypedArray typedArray = (TypedArray) this.f717g;
240.         if (typedArray.hasValue(i4) && (resourceId = typedArray.getResourceId(i4, 0)) != 0) {

```

## 8. App can be installed on a vulnerable unpatched Android version

|      |                                             |                                                                                                                                                                                                                                                                                                                                                                                                                 |
|------|---------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| i    | Affected Asset i.e. IP/URL/Application etc. | SMART Rajasthan Android Application - app-release_3_.apk                                                                                                                                                                                                                                                                                                                                                        |
| ii   | Observation/Vulnerability title             | App can be installed on a vulnerable unpatched Android version                                                                                                                                                                                                                                                                                                                                                  |
| iii  | Detailed observation / Vulnerable point     | The application does not specify a secure android:minimumSdkVersion or enforce version checks, allowing it to be installed and run on outdated, vulnerable Android versions that may lack critical security patches, increasing the risk of exploitation.                                                                                                                                                       |
| iv   | CVE/CWE                                     | <a href="#">CWE-1104</a>                                                                                                                                                                                                                                                                                                                                                                                        |
| v    | Control Objective                           | N/A                                                                                                                                                                                                                                                                                                                                                                                                             |
| vi   | Control Name                                | N/A                                                                                                                                                                                                                                                                                                                                                                                                             |
| vii  | Audit Requirement                           | N/A                                                                                                                                                                                                                                                                                                                                                                                                             |
| viii | Severity                                    | Medium                                                                                                                                                                                                                                                                                                                                                                                                          |
| ix   | Recommendation                              | <ul style="list-style-type: none"> <li>➤ This application can be installed on an older version of android that has multiple unfixed vulnerabilities. These devices won't receive reasonable security updates from Google. Support an Android version =&gt; Android 12 (API Level 31) or later, to receive reasonable security updates.</li> <li>➤ Update the app's minSdkVersion to latest version .</li> </ul> |
| x    | Reference                                   | N/A                                                                                                                                                                                                                                                                                                                                                                                                             |
| xi   | New or Repeat observation                   | New                                                                                                                                                                                                                                                                                                                                                                                                             |

### xii. References to evidences / Proof of Concept

#### PoC1:

```

1  version: 2.12.0
2  apkFileName: app-release (3).apk
3  usesFramework:
4    ids:
5      - 1
6  sdkInfo:
7    minSdkVersion: 24
8    targetSdkVersion: 36
9  packageInfo:
10   forcedPackageId: 127
11  versionInfo:
12   versionCode: 1
13   versionName: 1.0.0
14   doNotCompress:
15     - arsc
16     - png
17     - so
18     - assets/dexopt/baseline.prof
19     - assets/dexopt/baseline.profm

```

## Automated Tool Testing Observations

### Find the Attached DAST/SAST Tool Report

- *Annexures A* – Mobsf Report

# Appendices

N/A